
Cybersecurity Log Intelligence System

RAHUL KUMAR

June 29, 2026

1 Problem Statement

1.1 Background

Modern enterprises generate massive volumes of log data capturing user activities, authentication events, and security incidents. Organizations rely on these logs for monitoring, auditing, and compliance. Without automated analysis, critical security events may remain undetected for days or weeks.

1.2 Problem Identification

Manual log analysis is inefficient, time-consuming, and prone to error. Security analysts frequently overlook critical threats due to overwhelming volume and complexity. This leads to increased organizational risk and potential data breach incidents.

Key challenges include:

- **Volume:** Manual review impractical due to large-scale log generation
- **Threat Detection:** Difficulty identifying suspicious activities and attack patterns
- **Visualization:** No centralized dashboard for monitoring and analysis
- **Reporting:** Time-consuming, inconsistent manual report generation
- **Access Control:** No role-based access for different stakeholders
- **Multiple Files:** No ability to analyze multiple log files together in a single analysis
- **Email Distribution:** No automated report delivery to relevant personnel
- **Privacy:** Persistent storage of analysis data creates security risks

1.3 Impact

These challenges cause delayed threat detection, increased breach risk, inefficient resource use, inconsistent reporting, and compliance gaps.

1.4 Need for Automation

An automated solution is needed to process logs, detect threats, provide visualization, generate reports, enforce access control, support multiple files, distribute reports automatically, and maintain privacy without persistent storage of sensitive data.

2 System Requirements and Specifications

This section defines the detailed technical requirements that the system **MUST** satisfy. These requirements are organized into functional categories and specify exact behaviors, constraints, and quality attributes.

2.1 Security and Secure Coding Requirements

The system shall implement the following security controls:

- Input validation, data sanitization, and secure file upload validation
- Argon2id password hashing with parameterized database queries
- Principle of Least Privilege (PoLP) with secure secret management
- SAST (Bandit, with a `.bandit` config excluding the `tests/` and `Testcases/` directories) and dependency scanning (pip-audit)
- Session timeout: 15 minutes of inactivity
- Audit log retention: 180 days with auto-deletion

All dependencies shall be actively maintained and regularly updated. **YAML-based configuration** shall be used for rules, security settings, and email configuration.

2.2 Threat Detection Rules Management

The system shall provide threat detection capabilities with two types of rules:

2.2.1 Static Rules

Predefined rules that do not require any configurable parameter values. These rules are evaluated based on fixed conditions and patterns.

2.2.2 Behavioral Rules

Configurable rules that require threshold values or parameters. Examples include:

- Login attempts greater than specified threshold
- Failed access requests exceeding defined limit
- Unusual activity count above configured value

2.2.3 Administrator-Only Rule Management

Only the Administrator shall have permission to:

- Create rules
- Update rules
- Delete rules
- Configure threshold values
- Enable or disable rules
- Define the default rule set
- Publish staged rules (individually or all at once) to all IT Owners

2.2.4 IT Owner Rule Viewing Capability

IT Owners shall have read-only access to view the complete threat detection rule list. This enables IT Owners to:

- Understand which static and behavioral rules are currently applied by the Administrator
- Review rule conditions, severity levels, and configured threshold values
- Stay informed about the security monitoring criteria without having modification privileges
- Prepare appropriate log files knowing what patterns will be detected

IT Owners can view the rules through a dedicated read-only interface in the dashboard. No modification, selection, deselection, or customization is permitted.

2.2.5 Rule Staging and Publishing Policy

Administrator rule changes are **not** applied to IT Owners instantly. Instead the system uses an explicit **staging then publishing** workflow so the Administrator can validate a change against real logs before it affects anyone:

- Creating a new rule, editing a rule, or enabling/disabling a rule marks it **Pending (staged)**. A staged rule runs **only in the Administrator's own Home analysis** — IT Owners neither see nor run it.
- When satisfied, the Administrator clicks **Publish** on the rule (or **Publish all pending** for every staged rule at once). The rule then becomes **Published** — live for all IT Owners immediately — and the action is recorded in the audit log.
- Built-in seeded rules ship already published.

IT Owners shall not be permitted to create, modify, delete, enable/disable, publish, configure thresholds for, or select/deselect any rule. **They may view the published rule list** for transparency.

2.2.6 IT Owner Rule Usage

Every analysis performed by an IT Owner always uses the latest **published** Administrator-approved rule set. The publish/pending concept is never surfaced to IT Owners — their read-only Rules page shows only the rules that are live for them.

2.2.7 No-Code Behavioral Rule Builder

In addition to the built-in static and behavioral rules, the Administrator can author entirely new detection logic from the Web UI without writing code. A no-code rule is a **behavioral** rule defined by a keyword/regex **pattern**, a **threshold**, a **time window** and a **group-by** key (Source IP, Username, or Whole file). No-code rules are evaluated by the same vectorized engine as built-in rules and surface in the analysis results and PDF report with their concise recommended action.

2.2.8 Rule-Set Versioning and Framework Alignment

All detection rules are mapped to recognized security frameworks — **MITRE ATT&CK**, **OWASP Top 10 / API**, **NIST SP 800-53**, **ISO/IEC 27001 Annex A** and **CERT-In** — and each rule stores plain-language detection logic, a concise recommended action and an example log line for transparency. The dashboard displays a derived **rule-set version stamp** (version count and last-updated timestamp) so every user can confirm which configuration is active. Because all roles share a single rule set, any Administrator change applies **immediately to all IT Owners** and is recorded in the audit log.

2.3 Functional Feature Requirements

2.3.1 Multi-File Analysis

The Home page provides a single multi-file uploader that is the **sole source of truth** for an analysis: the user may drop **one or more log files** together and **Analyze** processes exactly the files currently staged in the drop box (combine results by dropping several files; exclude a file by removing it with the **x** before analyzing). Staged files appear in a collapsible **View / remove files** list. The staged files and the entered context **persist across page navigation** and are cleared only by **Clear & New Analysis**.

2.3.2 Analysis Context — Application / Product and LeanIX ID / PIF ID

Before an **IT Owner** can start an analysis, two **mandatory** context fields must be filled on the Home page:

- **Application / Product** — the application or product the logs belong to.
- **LeanIX ID / PIF ID** — the corresponding LeanIX / PIF identifier.

Both fields are marked with a red asterisk and the **Analyze button stays disabled until both are provided**. Once an analysis exists the two fields **lock** so that every file in the run shares the same Application/LeanIX combination. These values are written to the audit trail and appear on the PDF report, in the email body, and in the email subject line.

Administrator exception. The Administrator account is used to **test and publish detection rules**, so it is intentionally **excluded** from this workflow: the context fields are **not shown** on the Administrator's Home page, and the Administrator's own reports **omit** the Application, LeanIX and "Rules Applied" rows. The system distinguishes the two cases by whether any Application/LeanIX context is present — an IT Owner always supplies it; the Administrator never does.

2.3.3 Report Generation

The system shall handle reports as follows:

- PDF reports shall be downloaded directly through the browser to the user's local Downloads folder
- NO persistent storage of PDF reports in the system database
- Each report email carries **two attachments**: the **PDF report** and the full **findings table as a CSV** (Excel-friendly)
- The report shall be emailed to the user who uploaded the log file
- If the uploader is an **IT Owner**, it is emailed to that IT Owner **and the Administrator**
- If the uploader is an **Administrator**, it is emailed to the Administrator only

2.3.4 Data Storage Policy

- Analysis reports shall not be permanently stored in the system database
- Only audit logs and essential operational records shall be retained
- Temporary reports, uploaded log files, generated analysis artifacts, and temporary generated files shall be deleted after logout, session expiration, or completion of the configured cleanup process
- Application itself-generated audit logs shall be retained for a maximum of 180 days and automatically deleted thereafter
- All analysis data cleared upon logout or session timeout

2.3.5 Password Recovery (Forgot Password)

The login page shall provide a **Forgot Password** option available to both Administrators and IT Owners:

- The user enters their username or registered email address
- The system generates a new single-use temporary password and emails it to the registered email address
- When email (SMTP) is not configured, the temporary password shall instead be displayed on screen as a fallback
- The user is returned to the login page with the username pre-filled (and the temporary password shown when email is not configured)
- The user shall be forced to set a new permanent password on the next login
- The reset action shall be recorded in the audit log

2.4 Admin Credential Configuration

The system shall be pre-configured with a default Administrator account automatically created during database initialization with the following credentials:

Field	Value
User ID	admin
Password	Cybersecuritylogadmin@12798

Table 1: Default Administrator Credentials

2.4.1 Administrator First-Login Recovery Email Setup

On a freshly initialized database, the Administrator shall be required to configure a **recovery email address** before accessing the dashboard for the first time. This step is mandatory and cannot be skipped, and it ensures a valid address is available for critical system notifications and password recovery. The recovery email field is presented empty (no address is pre-filled) and must be entered and confirmed by the Administrator.

2.5 Password Policy Requirements

Policy	Requirement
Minimum Length	20 characters (both Administrator and IT Owner)
Character Types	Uppercase, lowercase, numbers, special characters
IT Owner Password Expiry	180 days (expired users forced to change before continuing)
Admin Password Expiry	Does not expire (manual DB change if needed)
Temporary Password	Random, single-use; emailed at registration
Password Storage	Argon2id hashing

Table 2: Password Policy Requirements

2.5.1 Self-Service Password Change

Both Administrators and IT Owners can change their own password at any time from the **Settings** page. A change is only accepted when the user:

- enters their **current password**, which is re-verified against the stored Argon2id hash before any change is applied (identity re-confirmation);
- supplies a **new password** that satisfies the full password policy above; and
- confirms the new password (the two entries must match).

The new password must not match any of the user's last 5 passwords. On success the change is recorded in the audit log and the user is **automatically signed out** and must sign in again with the new password.

2.6 User Management Requirements

The system shall support two primary user roles:

2.6.1 Administrator

The Administrator shall have full access to:

- Create, update, and delete database records where required
- Manage IT Owner accounts (create, update, delete)
- Configure and maintain threat detection rules
- Configure threshold values for behavioral rules
- Enable or disable threat detection rules
- Apply updated rule configurations globally to all IT Owners
- Review audit logs
- Perform all administrative operations supported by the system

2.6.2 IT Owner Registration and Authentication

IT Owners shall register through the web dashboard by providing:

- Desired User ID
- Email address

The system shall verify that the requested User ID is available. Upon successful registration, the system shall generate a unique random temporary password and send it to the registered email address. When email (SMTP) is not configured, the temporary password shall instead be displayed on screen as a fallback so it can be shared securely. After registration the user is taken to the login page with the username pre-filled. The temporary password shall be different for every registration.

After first login, the IT Owner shall be required to change the temporary password to a new password of their choice. Thereafter, IT Owners may change their password at any time from the **Settings** page. IT Owners shall be able to log out securely. User sessions shall automatically terminate after 15 minutes of inactivity.

2.6.3 Deferred Account Activation (Pending Registration)

To prevent abandoned or half-completed sign-ups from creating live accounts, IT Owner registration is **two-phase**: an account is created **only after the registrant sets their own permanent password**.

- Submitting the registration form does **not** create a user account. The system records a **pending registration** (username, email, and an Argon2id hash of the temporary password) and issues the temporary password (emailed, or shown once on screen as a fallback).
- At this stage **no User** record exists — the username does not yet occupy a real account, and nothing appears in user management or the audit history.
- The registrant signs in with the temporary password and is required to set a **permanent password**. Only at this point is the actual **User** account created (permanent Argon2id hash, 180-day expiry, first-login cleared) and the pending record removed.
- If the registrant exits before setting a permanent password, **no account is left behind**. Stale pending registrations are automatically purged after **7 days**.

2.7 Email Notification Requirements

2.7.1 During Report Generation:

1. Generate the PDF report and send it as an email attachment to the user who uploaded the log file
2. If an IT Owner uploads the file, the email is sent to that IT Owner **and the Administrator**
3. If the Administrator uploads the file, the email is sent to the Administrator only
4. For an IT Owner report, the email subject and body include the **Application / Product** and **LeanIX ID / PIF ID**; the Administrator's copy additionally prefixes the IT Owner's username to the subject

2.7.2 During IT Owner Registration:

1. Generate unique random temporary password
2. Send password to registrant's email address only (when SMTP is configured)
3. If email is not configured, display the temporary password on screen as a fallback
4. Temporary password shall be different for every registration
5. Force password change on first login

2.7.3 During Password Recovery:

1. Generate a new single-use temporary password for the matched account
2. Email it to the account's registered email address (or display it on screen if SMTP is not configured)
3. Force the user to set a new permanent password on the next login

Email notification shall use SMTP with TLS encryption.

2.8 Session Management Requirements

- Session timeout: **15 minutes** of inactivity
- Auto-logout with redirect to login page
- Session data securely cleared upon termination
- All associated session tokens invalidated upon logout or timeout
- Temporary analysis data cleared upon session expiration

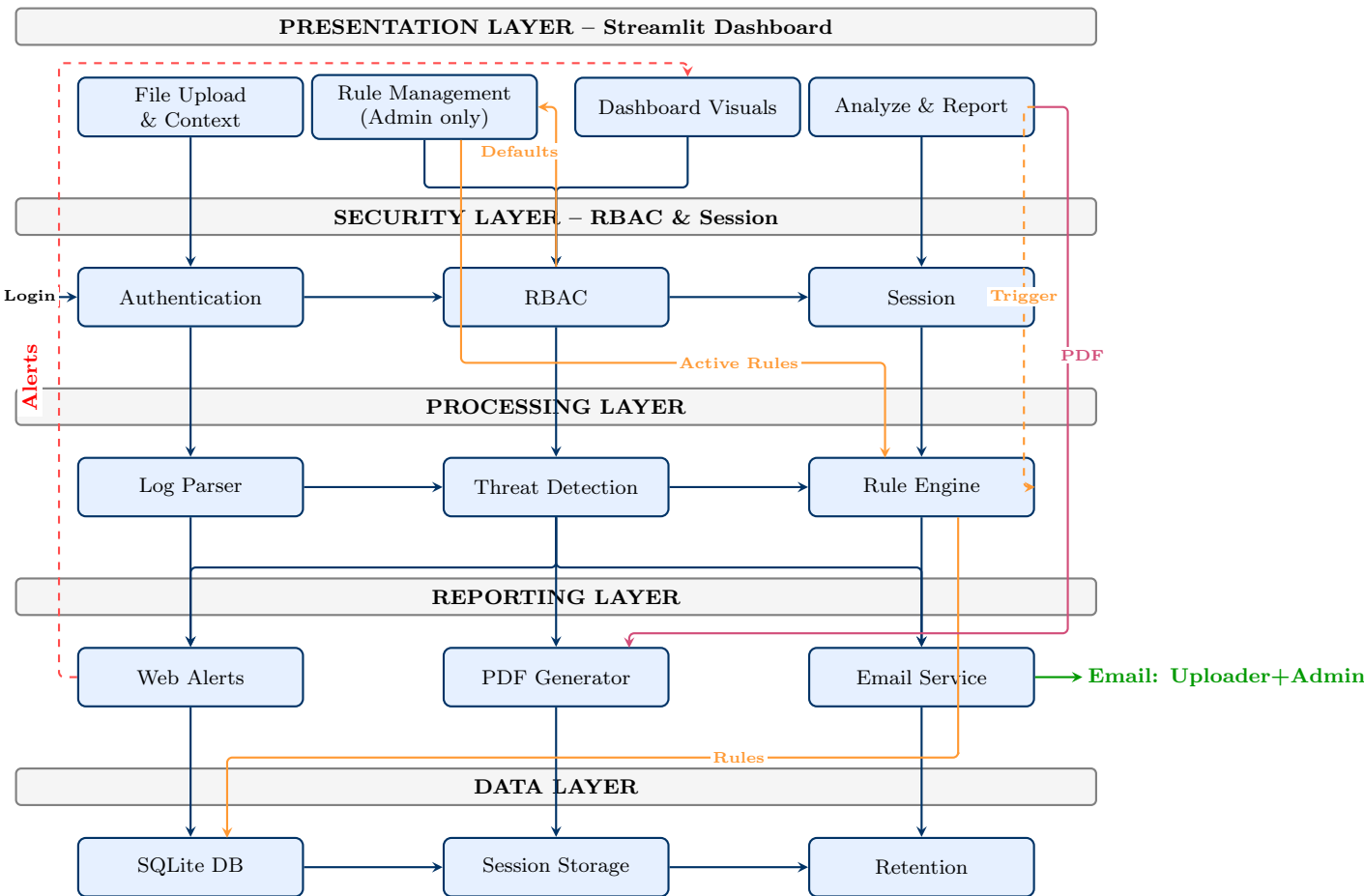
2.9 Data Retention Requirements

Data Type	Retention	Action After Expiry
Audit Logs	180 days	Auto-delete
IT Owner Passwords	180 days	Force change at next login with notification
Temporary Passwords	Single-use	Invalidated after use
Analysis Results	Session only	Cleared on logout or session expiry
Uploaded Log Files	Session only	Cleared after analysis completion
PDF Reports	Not stored	Generated on-demand, deleted after download/email
Detection Rules	Persistent	Stored in database/YAML, Admin managed

Table 3: Data Retention Policy

3 System Architecture

Figure 3 presents the complete system architecture block diagram with proper data flow.



Layer	Components & Responsibilities
Presentation Layer	Streamlit dashboard with visualizations, multi-file upload, Application / LeanIX context capture (IT Owner) , registration interface, Admin rule management UI , IT Owner read-only rule viewer
Security Layer (RBAC)	Two-role access control (Administrator and IT Owner), Argon2id authentication, session management (15 min timeout), Administrator-only rule modification , IT Owner read-only rule access
Processing Layer	Multi-format log parsing, Admin-configured rule engine , vectorized threat detection, multi-file aggregation, executed in process-isolated workers for concurrency
Reporting Layer	Web UI alerts, PDF report generation (local download), SMTP email service (uploader; plus the Administrator when an IT Owner runs it) including the Application / LeanIX context
Data Layer	SQLite database (audit logs + Admin-defined rules), session-based temporary storage, retention policy (180 days for audit logs)

3.1 Complete System Workflow

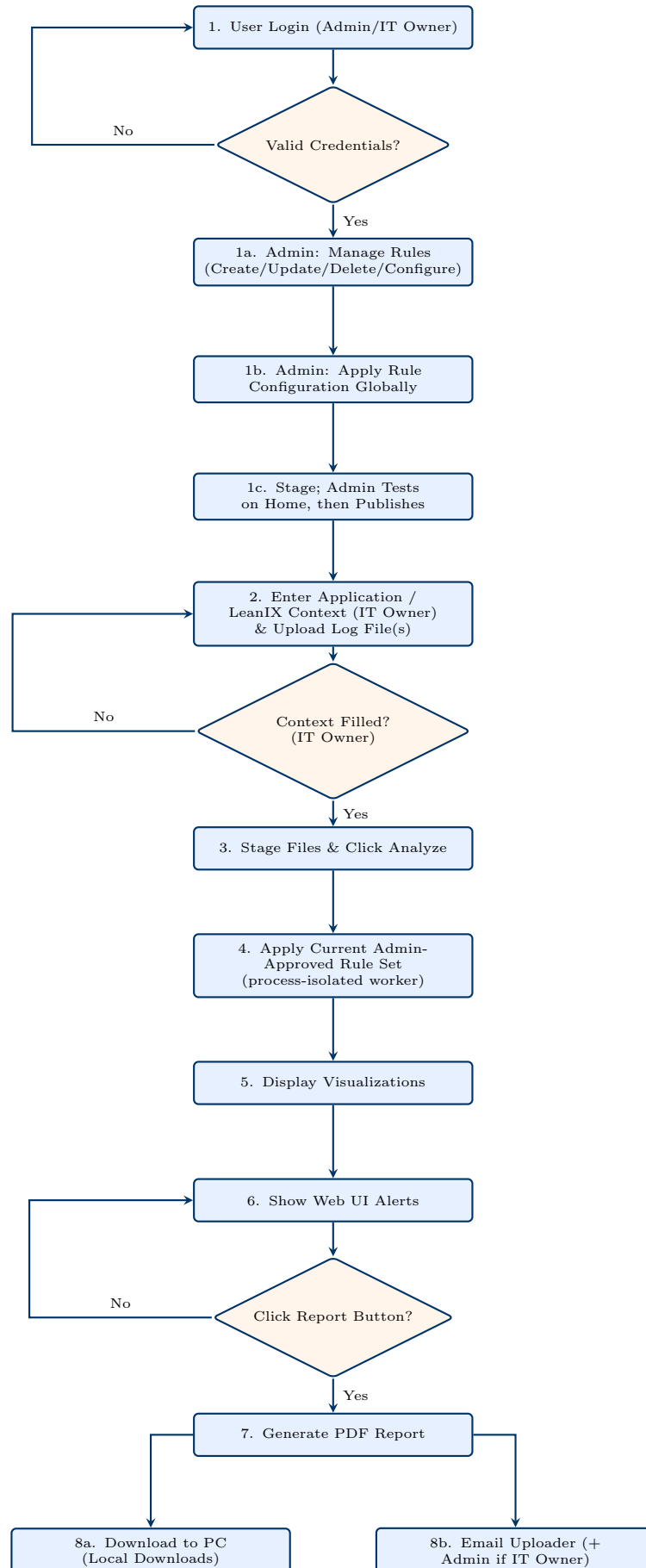


Figure 1: Complete System Workflow

3.2 Supported Log File Formats

The system supports secure upload and analysis of multiple industry-standard log file formats:

Format	Extension	Description
Raw Text Log	.log, .txt	Generic server and application logs
Syslog	.syslog	Standard Linux/Unix system logs
CEF Format	.cef	Common Event Format (SIEM compatible)
Web Server Logs	.log	Apache/Nginx access and error logs

3.3 Dashboard Visualizations

The Streamlit dashboard presents the following visualizations and analysis tools after log analysis:

Visualization / Tool	Description
Threat Summary Cards	Display counts of CRITICAL, HIGH, MEDIUM, LOW threats with color-coded backgrounds
Severity Distribution Chart	Pie chart showing percentage distribution of threat severities
Threat Timeline Graph	Line chart showing threat frequency over time
Top Attack Sources	Bar chart of IP addresses with most threat occurrences
Top Involved Users	Bar chart of usernames most frequently involved in findings
Threat Type Distribution	Horizontal bar chart of different threat types detected
Findings by Rule Type	Static vs behavioral finding counts
Threats by Rule (Table)	Aggregated count of findings per rule
Detailed Threat Table	Sortable table with timestamp, severity, type, description, source IP
Findings Search	Free-text search across findings (IP, username, rule, description)
Findings CSV Export	Download the complete findings table as CSV (full, untruncated data)
Files Analyzed List	Lists every log file included in the current analysis run
Admin Rule Management Panel	Admin-only interface for creating, modifying, deleting detection rules
IT Owner Rule Viewer	Read-only, severity-ordered (Critical → Low), colour-coded cards showing every active rule's detection logic, severity, threshold, time window, group-by key, recommended action and framework mapping (MITRE / OWASP / NIST / ISO 27001 / CERT-In), plus the active rule-set version stamp

Table 4: Dashboard Visualization Components

3.4 Concurrency and Scalability

To remain responsive when many IT Owners use the system simultaneously, the heavy log analysis (parsing + rule evaluation) does **not** run inside the web-server process. Instead:

- Each analysis job is executed in a **separate, process-isolated worker** so CPU-bound work never blocks the Streamlit server's interpreter (avoids the Python GIL bottleneck).
- A **bounded worker pool** (`services/analysis_runner.py`) caps how many analyses run concurrently so a burst of users cannot exhaust CPU/RAM; additional jobs queue until a worker frees up.
- If a worker process cannot be launched, the system **falls back to in-process analysis** automatically, so functionality is never lost.
- A worker crash is **isolated** and cannot bring down the web server.

3.5 Database Schema

The SQLite database shall consist of the following tables:

Table Name	Purpose and Columns
users	User credentials (username, password_hash, email, role, created_at, password_changed_at, password_expiry, last_login, is_active, password_type, is_first_login)
audit_logs	User action trail (user_id, action, timestamp, ip_address, details, file_name, application , leanix_id)
sessions	Active sessions (user_id, session_token, created_at, last_activity, expiry_time)
password_history	Password change history (user_id, password_hash, created_at)
pending_registrations	Unactivated IT Owner sign-ups (id, username, email, temp_password_hash, created_at); a row is promoted to a users record once the registrant sets a permanent password, then deleted. Auto-expires after 7 days.
detection_rules	Built-in and admin/custom rules (id, rule_name, rule_type [static behavioral custom], condition, severity, description, is_static, default_threshold, time_window_seconds, group_by, is_enabled, detection_logic, recommended_action, framework_refs, example_log, why_suspicious, security_impact, is_propagated [published flag], created_by, created_at, updated_at)

Table 5: Database Schema

3.6 Password-Related Database Fields

Column Name	Purpose
password_hash	Argon2id hash (temporary or permanent)
password_type	ENUM('temporary', 'permanent')
password_changed_at	Timestamp of password creation
password_expiry	Expiry timestamp for permanent passwords (180 days)
is_first_login	Flag for forcing password change

Table 6: Password-Related Database Fields

3.7 Password State Management

State	Duration	Description
Temporary	First login only	Generated during registration, sent via email, forces change on first login
Active	Days 1-179	Permanent password valid, normal access
Expired	Day 180+	Forces password change at next login with popup notification

Table 7: IT Owner Password States

4 Threat Detection Rules

The system ships with a curated library of **45 detection rules** organized into two categories. Every rule is mapped to recognized security frameworks (**MITRE ATT&CK**, **OWASP Top 10 / API**, **NIST SP 800-53**, **ISO/IEC 27001 Annex A** and **CERT-In**), and each carries presentation metadata — plain-language *detection logic*, a concise *recommended action*, *framework references* and an *example log line* — so the dashboard can render a full, data-driven card for every rule. **IT Owners can view all active rules** (including thresholds, time windows and framework mappings) through the read-only rule viewer.

Category	Description
Static (Signature) Rules	Fixed regular-expression / signature conditions (SQL injection, XSS, path traversal, web shells, reverse shells, etc.). Fire on a single matching log line.
Behavioral (Threshold) Rules	Count events grouped by Source IP / Username / Whole-file and fire when a configurable count is met within a time window (brute force, credential stuffing, error spikes, etc.). Admin no-code rules are behavioral rules authored from the Web UI (pattern + threshold + time window + group-by), with no Python changes.

4.1 User Behavior Analysis Rules (Static)

Rule Name	Severity	What It Detects	Frameworks
Dormant Account Activity	HIGH	Long-inactive account suddenly becomes active	MITRE T1078; NIST AC-2(3)
Concurrent Sessions	HIGH	One account with simultaneous sessions from different sources	MITRE T1078; NIST AC-10
Geographic Anomaly	MEDIUM	Login from an unusual region / impossible travel	MITRE T1078; NIST AC-7
Unusual Working Hours	LOW	Majority of activity outside 09:00–17:00	MITRE T1078; NIST AU-6
Off-Hours Access	MEDIUM	Successful login between 00:00 and 05:00	MITRE T1078; NIST AU-6

Table 8: User Behavior Analysis Rules (Static)

4.2 Static Attack-Pattern Detection Rules

Rule Name	Severity	What It Detects	Frameworks
SQL Injection Attempt	HIGH	UNION SELECT, OR 1=1, DROP TABLE, stored-procedure abuse	MITRE T1190; OWASP A03; NIST SI-10
Path Traversal Attempt	HIGH	../ and URL-encoded variants escaping the web root	MITRE T1083; OWASP A01; NIST AC-3
Command Injection	CRITICAL	Shell metacharacters (; — && \$() “) chained with OS commands	MITRE T1059; OWASP A03; NIST SI-10
XSS Attempt	MEDIUM	Script tags, JS event handlers, javascript:/vbscript: URIs	MITRE T1059.007; OWASP A03; NIST SI-10
Directory Scanning	MEDIUM	Probing of admin panels, .git/.env, config/backup files	MITRE T1595.003; OWASP A05; NIST RA-5
Abnormal HTTP Methods	HIGH	TRACE, CONNECT and WebDAV verbs used in recon	MITRE T1595; OWASP A05; NIST CM-7

4.3 Access Control Detection Rules (Static)

Rule Name	Severity	What It Detects	Frameworks
Unauthorized Access Attempt	HIGH	HTTP 401/403 and access-denied responses	MITRE T1190; OWASP A01; NIST AC-3
Privilege Escalation	CRITICAL	sudo/su abuse, role grants, SUID, gained root/admin	MITRE T1068/T1548; NIST AC-6
Sensitive Resource Access	HIGH	/etc/passwd, /etc/shadow, SSH keys, *.pem, secret stores	MITRE T1552; NIST AC-3
API Key Misuse	MEDIUM	Invalid/expired/revoked API keys and bearer tokens	MITRE T1552.001; OWASP API2; NIST IA-5
Session Hijacking Pattern	CRITICAL	Session fixation/hijacking, token mismatch, CSRF	MITRE T1539; OWASP A07; NIST SC-23
Account Lockout Event	HIGH	Account locked after exceeding failed-auth threshold	MITRE T1110; NIST AC-7
Successful Login After Failures	MEDIUM	Login success right after 3+ consecutive failures	MITRE T1110; NIST AC-7

Table 10: Access Control Detection Rules (Static)

4.4 Modern / Advanced Threat Coverage (Static)

These rules extend the library with current attacker techniques and notable CVEs, each mapped to MITRE ATT&CK.

Rule Name	Severity	What It Detects	Frameworks
Log4Shell / JNDI Injection	CRITICAL	jndi:ldap/rmi/dns lookup payloads (CVE-2021-44228)	MITRE T1190; CVE-2021-44228; CERT-In
Web Shell Upload / Access	CRITICAL	Known shell names, eval-over-base64, scripts in upload paths	MITRE T1505.003; OWASP A03; NIST SI-3
PowerShell Encoded Command	HIGH	Encoded/hidden PowerShell, IEX / Download-String	MITRE T1059.001; NIST SI-4
Credential Dumping	CRITICAL	LSASS dumps, NTDS.dit / SAM extraction, known tools	MITRE T1003; NIST IR-4
Reverse Shell Indicator	CRITICAL	bash to /dev/tcp, nc -e, mkfifo—nc, python socket shells	MITRE T1059/T1571; NIST SC-7
DNS Tunneling / Exfiltration	HIGH	Long high-entropy subdomains, TXT abuse, known tooling	MITRE T1048.003/T1071.004; NIST SC-7
Cloud Metadata SSRF	HIGH	Requests to 169.254.169.254 / cloud IMDS endpoints	MITRE T1552.005; OWASP A10; NIST SC-7
Ransomware File Activity	CRITICAL	Mass-rename to crypto extensions, ransom-note creation	MITRE T1486; NIST CP-9
XML External Entity (XXE)	HIGH	External ENTITY/-DOCTYPE, file:// / php://filter wrappers	MITRE T1190; OWASP A05; NIST SI-10
LDAP Injection	HIGH	LDAP filter metacharacters (*),), (— in directory queries	MITRE T1190; OWASP A03; NIST SI-10
Server-Side Request Forgery (SSRF)	HIGH	User URL targeting loopback / RFC1918 internal ranges	MITRE T1090; OWASP A10; NIST SC-7
Security Scanner Activity	MEDIUM	sqlmap, nikto, nmap, nuclei and similar tool signatures	MITRE T1595; OWASP A05; NIST RA-5
OAuth / Token Abuse	MEDIUM	Refresh-token reuse/revocation, bad redirect_uri, consent phishing	MITRE T1528; NIST IA-5

4.5 Behavioral Detection Rules (Configurable Thresholds)

Behavioral rules aggregate events by the listed **Group-by** key and fire when the **Default** count is met within the time window. All defaults follow industry guidance (NIST SP 800-63B, OWASP ASVS) and are fully Administrator-configurable from the Web UI.

Rule Name	Default	Group-by	Severity	Frameworks
Brute Force Attack	≥ 5 in 60 sec	Source IP	CRITICAL	MITRE T1110.001; NIST AC-7
Repeated Failed Logins	≥ 5 in 15 min	Username	HIGH	MITRE T1110; NIST AC-7
Rapid Login Attempts	≥ 20 in 10 sec	Whole file	CRITICAL	MITRE T1110.004; NIST AC-7
Multiple User Failures	≥ 5 users in 5 min	Source IP	HIGH	MITRE T1110.004; NIST AC-7
Repeated Access Denials	≥ 10 in 5 min	Source IP	HIGH	MITRE T1190; NIST AC-3
Error Rate Spike	≥ 50 in 5 min	Whole file	MEDIUM	MITRE T1499; NIST SI-4
Service Crash Loop	≥ 3 in 2 min	Whole file	HIGH	MITRE T1499; NIST SI-4
Rapid Sequential Actions	≥ 50 in 60 sec	Whole file	MEDIUM	MITRE T1499; NIST SI-4
Mass Data Access	≥ 1000 in 1 hr	Whole file	MEDIUM	MITRE T1530/T1213; NIST AC-6
Resource Exhaustion	Any occurrence	Whole file	HIGH	MITRE T1499.001; NIST SC-5
Unexpected Shutdown	Any occurrence	Whole file	HIGH	MITRE T1529; NIST IR-4
Configuration Change	Any occurrence	Whole file	MEDIUM	MITRE T1562; NIST CM-3
Database Error Spike	≥ 20 in 5 min	Whole file	MEDIUM	MITRE T1190; NIST SI-4

4.6 No-Code Behavioral Rules (Admin-Authored)

Administrators can build entirely new detection logic from the dashboard — no Python required — by supplying a keyword/regex **pattern**, a **threshold**, a **time window** and a **group-by** key (Source IP / Username / Whole file). These no-code rules are **behavioral** rules: they are evaluated by the same vectorized engine as the built-in rules and appear in results and the PDF report with their concise recommended action. A reference example ships by default:

Rule Name	Default	Group-by	Severity	Frameworks
MFA Fatigue / Push Bombing	≥ 5 in 5 min	Username	HIGH	MITRE T1621; NIST IA-2

Table 13: No-Code Behavioral Rule (shipped example)

4.7 Framework Alignment and Rule Metadata

Every rule record stores framework references and presentation metadata, making the rule viewer fully data-driven (including for admin-authored no-code rules):

Metadata Field	Purpose
detection_logic	Plain-language description of how and when the rule fires
recommended_action	Concise (≤ 2 line) mitigation / investigation step shown on the card and PDF
framework_refs	MITRE ATT&CK / OWASP / NIST 800-53 / ISO 27001 / CERT-In mapping
example_log	A representative log line that would trigger the rule
group_by	Aggregation key for threshold rules (source_ip / user-name / global)

Table 14: Rule Presentation and Framework Metadata

5 Software Bill of Materials (SBOM)

Component	Version	Vendor	Tag
Visual Studio Code	1.122.0	Microsoft Corporation	Code Editor / IDE
Anaconda (Conda)	25.3.0	Anaconda, Inc.	Python Distribution
Python	3.12.13	Python Software Foundation	Programming Language
Streamlit	1.54.0	Streamlit Inc.	Web Dashboard
SQLAlchemy	2.0.41	SQLAlchemy Authors	ORM / Database
Pandas	2.2.3	Pandas Development Team	Data Processing
Plotly	6.5.0	Plotly Technologies Inc.	Visualization
ReportLab	4.3.1	ReportLab Inc.	PDF Generation
PyYAML	6.0.2	PyYAML Contributors	Configuration
Cryptography	48.0.1	PyCA	Encryption / Security
Passlib	1.7.4	Passlib Project	Password Hashing
argon2-cffi	23.1.0	argon2-cffi Contributors	Password Hashing
bcrypt	4.3.0	OpenBSD Project	Password Hashing
python-dotenv	1.2.2	Dotenv Project	Secret Management
email-validator	2.3.0	email-validator Contributors	Email Validation
itsdangerous	2.2.0	Pallets Projects	Session Security
watchdog	6.0.0	Watchdog Project	File Monitoring
tzdata	2026.2	Python Software Foundation (IANA)	Timezone Database (IST on Windows)
pytest	9.0.3	Pytest Project	Testing
pytest-cov	6.1.1	pytest-cov Contributors	Test Coverage
bandit	1.8.3	Python Code Quality Authority	Static Application Security
pip-audit	2.9.0	Python Packaging Authority	Vulnerability Scanning
msgpack	1.2.1	MessagePack / Inada Naoki	Serialization (transitive via pip-audit; security-pinned)

6 Email Report Sample

When a report is generated, the user who uploaded the file receives an email with the PDF report and the findings CSV attached. **When an IT Owner generates the report, a copy is also sent to the Administrator (with the IT Owner's username prefixed to the subject); an Administrator's own report is sent to the Administrator only.** An IT Owner report carries the **Application / Product** and **LeanIX ID / PIF ID** in both the subject and the body; the Administrator's own report omits the Application, LeanIX and "Rules Applied" lines.

Subject: AZURE | 2345-Log Analysis Report-Jun 20,2026
(Admin copy when an IT Owner runs it -- username prefixed:
"userx : AZURE | 2345-Log Analysis Report-Jun 20,2026")
(Administrator's own report has no context:
"Log Analysis Report-20 Jun,2026")

Dear userx,

The security analysis of the uploaded log file(s) has been completed.
A summary of the findings is provided below.

Report Details:

Application/Product:	AZURE	<- IT Owner reports only
LeanIX ID / PIF ID:	2345	<- IT Owner reports only
Generated By:	userx (user@companyname.com)	
Analysis Date:	20-06-2026 14:32:10 IST	
Rules Applied:	Administrator-approved rule set	<- IT Owner reports only

Files Analyzed:

1. server_log_jun18.log
2. server_log_jun19.log
3. server_log_jun20.log

Threat Summary:

Total Threats:	23
Critical:	3
High:	8
Medium:	7
Low:	5

Attached: security_report_20-06-2026.pdf
threat_findings_20260620_143210.csv

For detailed results, please refer to the attached PDF report and the complete findings table in CSV format.

Note: This report is NOT stored on the server. Please save a copy for your records.

Best Regards,
Cybersecurity Log Intelligence System

7 Setup and Installation Guide

7.1 Project Directory Structure

The project follows a modular architecture to improve maintainability, scalability, and separation of concerns. The directory structure is organized as follows:

```
Cybersecurity Log Intelligence System/
|
+-- main.py                # Application entry point
+-- app.py                 # Streamlit routing
+-- .env                   # Environment secrets (copy from .env.example)
+-- .env.example           # Environment template
+-- .gitignore             # Files excluded from version control
+-- requirements.txt       # Python dependencies
+-- .bandit                # Bandit scan config (excludes tests/ + Testcases/)
|
+-- .streamlit/
|   +-- config.toml        # Streamlit theme + server config
|
+-- config/
|   +-- settings.py        # App constants, IST timezone, worker settings
|   +-- detection_rules.yaml # Default detection rules
|
+-- database/
|   +-- models.py          # SQLAlchemy ORM models
|   +-- db.py              # Database engine & session
|   +-- init_db.py         # Tables + admin + rules setup
|
+-- auth/
|   +-- password.py        # Argon2id hashing & policy
|   +-- session_manager.py # Session CRUD & 15-min timeout
|   +-- access_control.py  # Role-based access guards
|
+-- services/
|   +-- audit_service.py   # Audit logging (IST timestamps)
|   +-- email_service.py  # SMTP email with PDF attachments
|   +-- user_service.py   # User CRUD & authentication
|   +-- log_parser.py     # Multi-format log parsing
|   +-- threat_engine.py  # Static & behavioral rule evaluation (vectorized)
|   +-- _static_match.py  # Stdlib-only regex matcher for spawned workers
|   +-- recommendations.py # Remediation guidance
|   +-- report_service.py  # PDF generation (in-memory)
|   +-- analysis_runner.py # Bounded-concurrency job submission
|   +-- analysis_worker.py # Process-isolated analysis worker
|
+-- ui/
|   +-- components.py     # CSS, navigation, charts
|   +-- login_page.py     # Login + Forgot Password + Admin Setup
|   +-- register_page.py  # IT Owner registration
|   +-- dashboard_page.py # Home: upload + analyze + results (all-in-one)
|   +-- rules_page.py     # Rule viewer (Admin + IT Owner)
|   +-- users_page.py     # User management (Admin only)
|   +-- settings_page.py  # SMTP config + Change Password
|   +-- audit_page.py     # Audit logs (Admin only)
|
+-- utils/
|   +-- validators.py      # Input validation
|   +-- temp_file_manager.py # Auto-cleanup of temp files
|   +-- crypto_utils.py    # Cryptographic helpers
|
+-- tests/
|   +-- conftest.py        # Test fixtures
|   +-- test_password.py   # Password policy tests
|   +-- test_log_parser.py # Log parsing tests
|   +-- test_threat_engine.py # Rule engine tests
|   +-- test_user_service.py # User service tests
|
+-- Testcases/
|   +-- <Rule Name>.log    # Per-rule .log samples + security test scripts
|   +-- fuzz_test.py      # Fuzz harness (parsers, extractors, rule engine)
|   +-- generate_all_threats_log.py # Log generator covering every rule
|
+-- temp/                  # Temporary uploaded files (auto-cleaned)
```

7.2 Complete Installation Script

7.2.1 Step 1: Create Conda Environment

```
conda create -n cybersec python=3.12 -y
```

7.2.2 Step 2: Activate Environment

```
conda activate cybersec
```

7.2.3 Step 3: Upgrade pip

```
python -m pip install --upgrade pip
```

7.2.4 Step 4: Install Core Packages

```
pip install streamlit==1.54.0 sqlalchemy==2.0.41 passlib==1.7.4  
argon2-cffi==23.1.0 pandas==2.2.3 plotly==6.5.0 reportlab==4.3.1  
pyyaml==6.0.2 email-validator==2.3.0 python-dotenv==1.2.2  
bcrypt==4.3.0 itsdangerous==2.2.0 cryptography==48.0.1  
watchdog==6.0.0 tzdata==2026.2
```

7.2.5 Step 5: Install Development and Security Tools

```
pip install bandit==1.8.3 pip-audit==2.9.0
```

7.2.6 Step 6: Install Testing Tools

```
pip install pytest==9.0.3 pytest-cov==6.1.1
```

Tip: You can install everything in one step with `pip install -r requirements.txt` instead of Steps 4–6.

7.2.7 Step 7: Configure Environment Variables

Open the `.env` and configure the required values :

- **Generate a secure APP_SECRET_KEY:** Run this command in your terminal:

```
python -c "import secrets; print(secrets.token_hex(32))"
```

- **Set SMTP_USER:** Enter your Gmail email address
- **Generate a 16-digit SMTP_PASS (App Password):**
 1. Verify that 2-Factor Authentication is enabled on your Gmail account
 2. Navigate to <https://myaccount.google.com/apppasswords>
 3. Enter a name for the app (e.g., "Cybersecurity Log System")
 4. Click "Generate" to create a 16-digit App Password

5. Copy the generated password and paste it as `SMTP_PASS` in your `.env` file

- **(Optional) Concurrency tuning:** Set `ANALYSIS_MAX_WORKERS` (max concurrent analysis worker processes; default: CPU count – 1, capped at 8) and `USE_WORKER_PROCESS` (set to 0 to force in-process analysis for debugging).

7.2.8 Step 8: Verify Installed Packages

```
pip list
```

7.2.9 Step 9: Verify No Known Vulnerabilities

```
pip-audit
```

7.3 Delete Existing Database (If Needed)

Delete the existing database:

```
Remove-Item cybersec.db -ErrorAction SilentlyContinue
```

Verify that it has been deleted:

```
Test-Path cybersec.db
```

Note: The database is automatically recreated with the default administrator account and all pre-configured threat detection rules on the next application startup.

7.4 Run the Application

```
python main.py
```

The application will automatically open in your browser at `http://localhost:8501`.

7.5 To terminate the Session

```
Ctrl + C in the PowerShell Terminal
```

7.6 Running the Test Suite and Static Analysis

Run the automated tests:

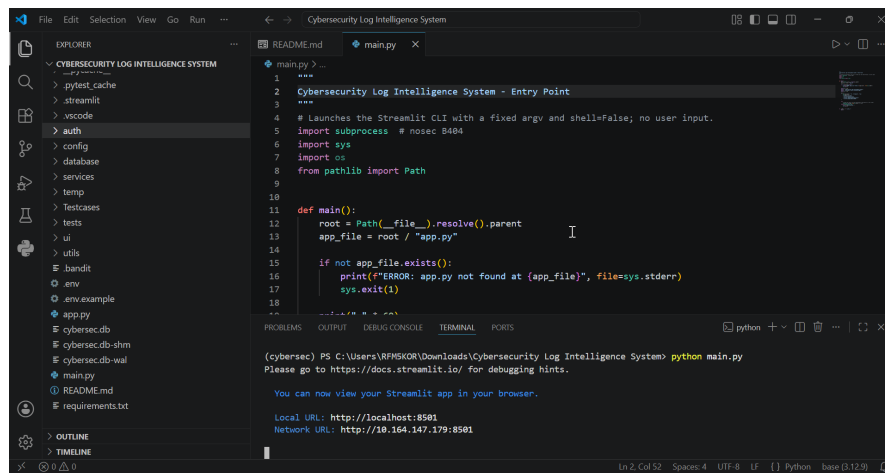
```
pytest
```

Run the security static analysis:

```
bandit -r .
```

8 Prototype

8.1 VS Code Setup



8.2 Sign In Page

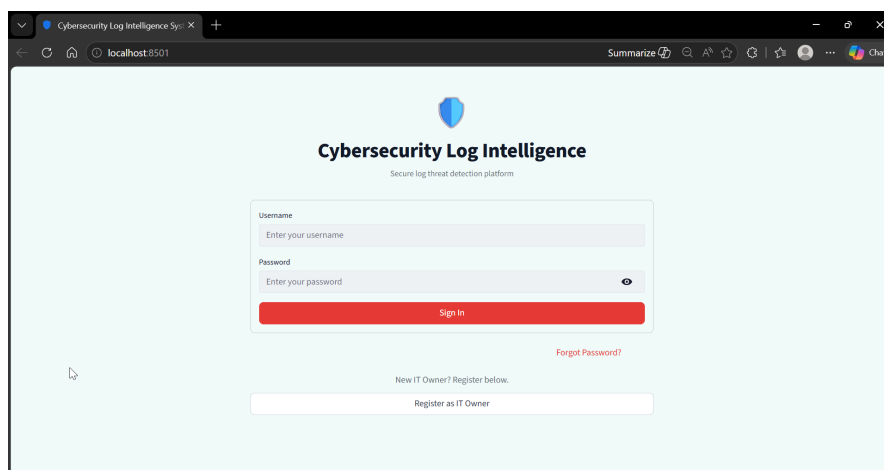


Figure 2: Sign In/ Register interface

8.3 Administrator Interface

8.3.1 Admin Homepage

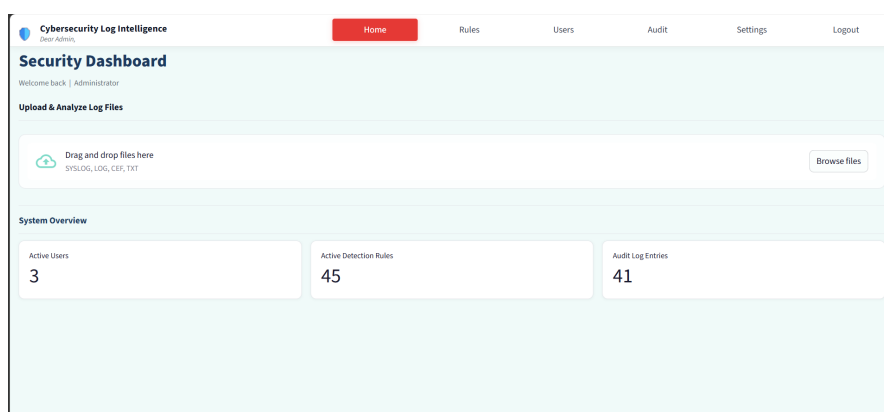


Figure 3: Admin Home with System Overview

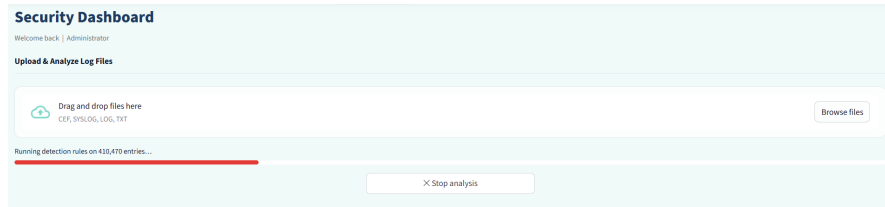


Figure 4: Admin Homepage during Log file analysis

8.3.2 Admin Rules Page

Admin can create, edit, enable, and disable the threat detection rules for all IT Owners

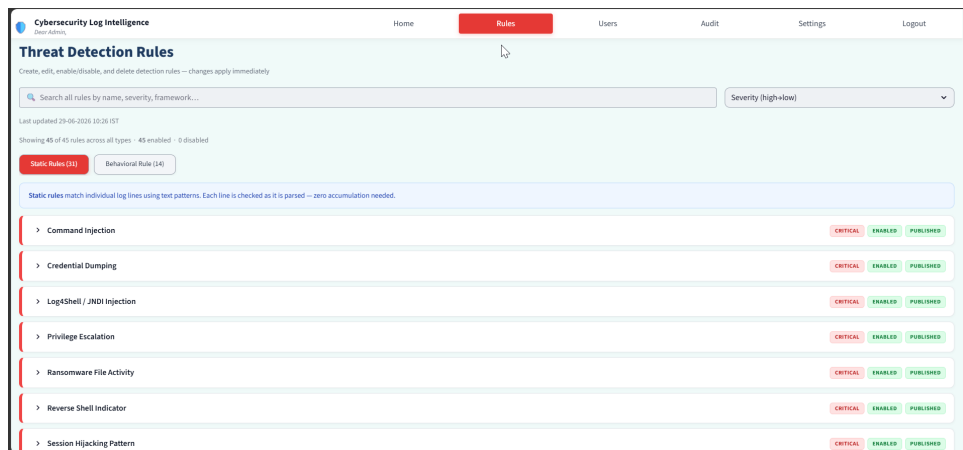


Figure 5: All threat dectection rules with current status

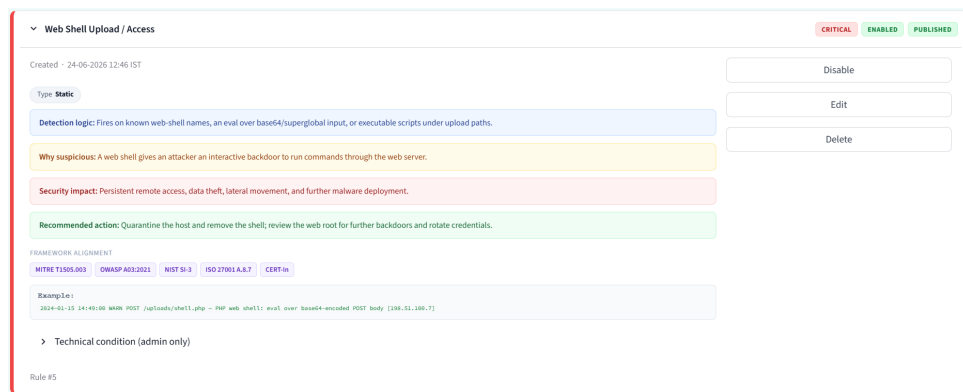


Figure 6: Configurable Threat detection rules

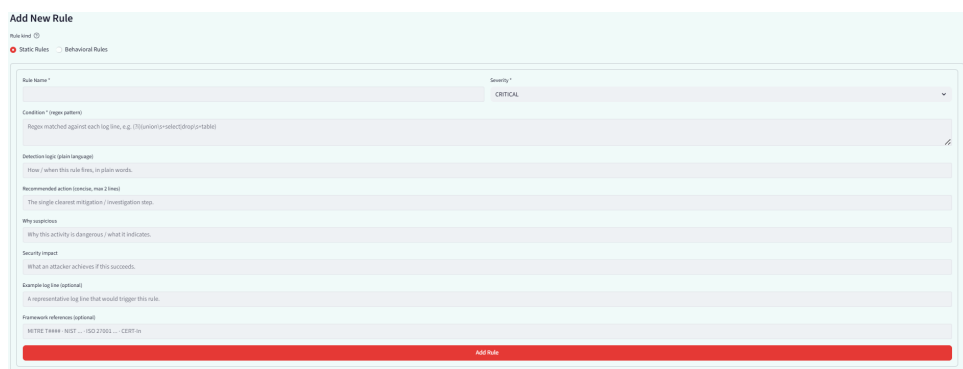


Figure 7: Admin can add new Static/Behavioral rules

8.3.3 Admin Users Page

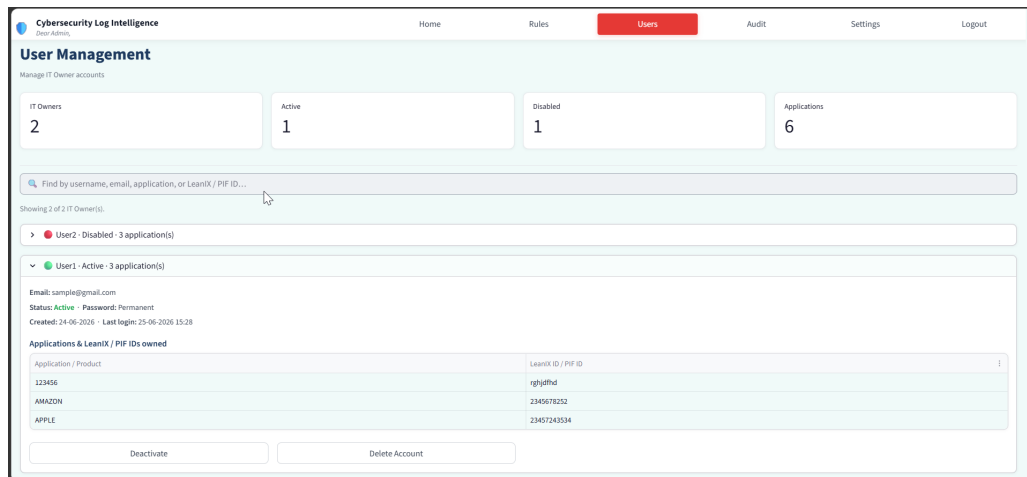


Figure 8: Admin can manage IT Owner's account

8.3.4 Admin Audit Page

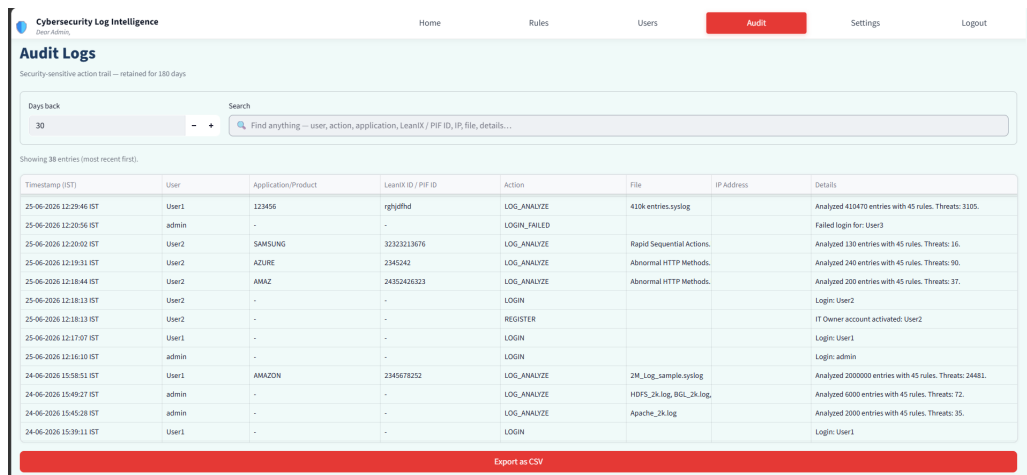


Figure 9: Admin can view the application Logs

8.3.5 Admin Settings Page

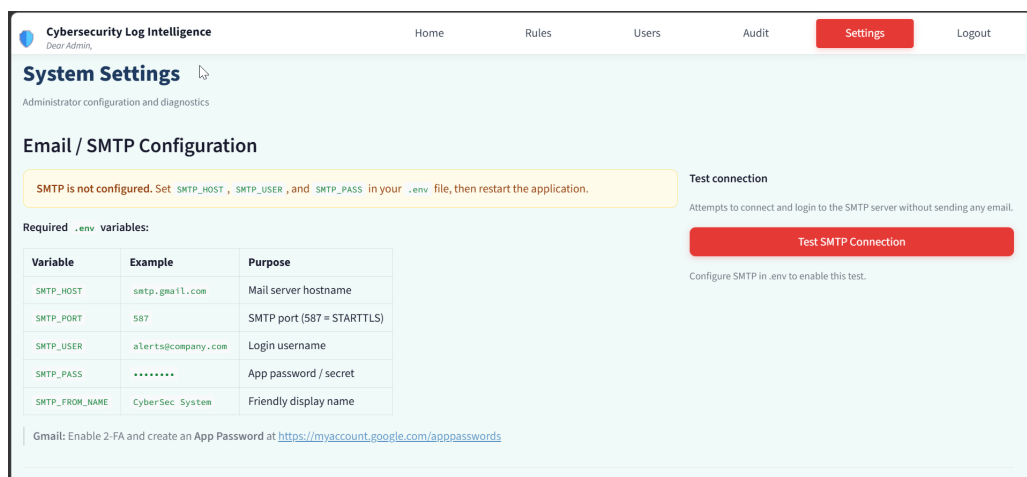


Figure 10: Admin can test email, view active sessions, and update its account password

8.4 IT Owner Interface

8.4.1 IT Owner Home Page

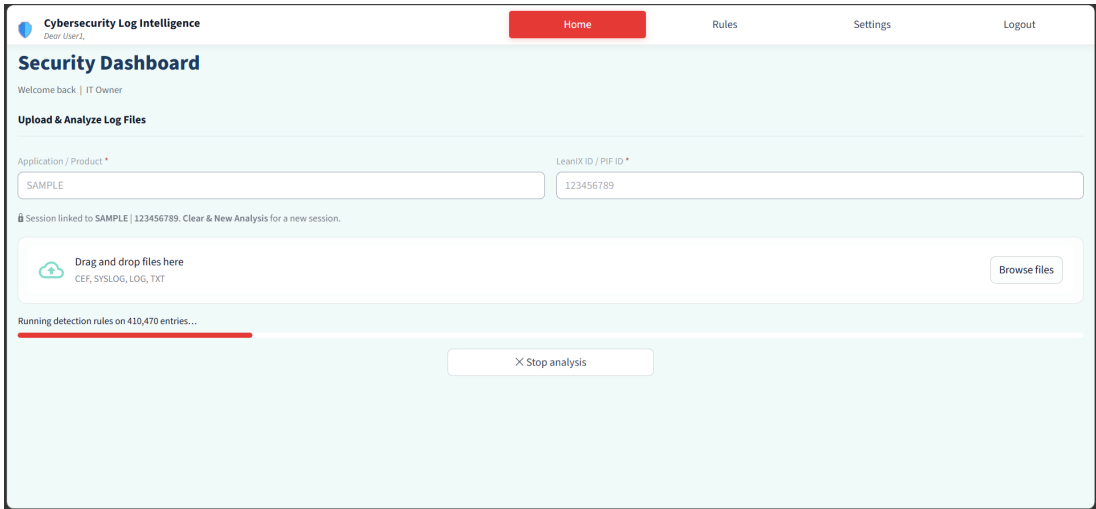


Figure 11: Application/Product and LeanIX ID/PIF ID must be provided by all IT Owners before initiating log file analysis.

8.4.2 IT Owner Rules Page

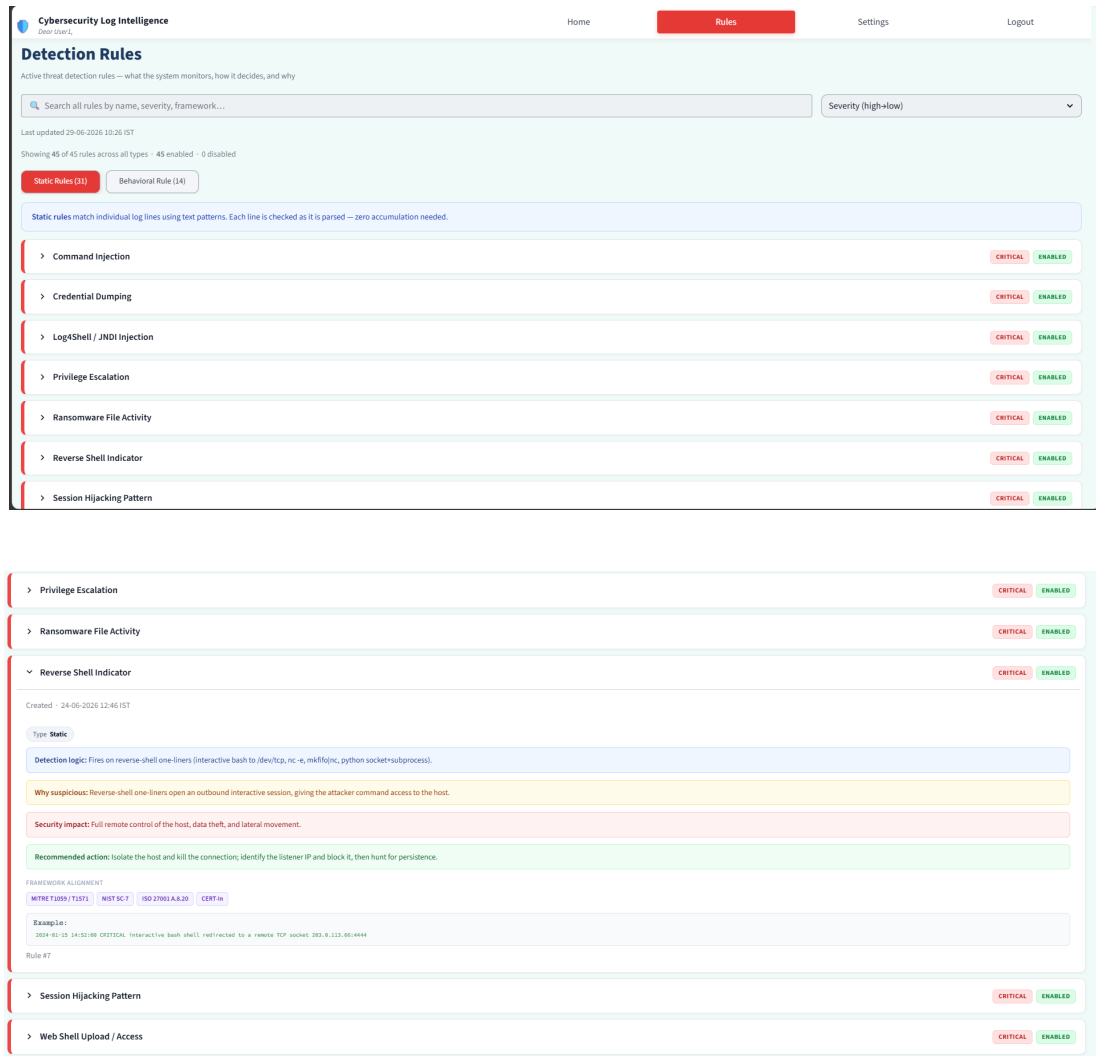


Figure 12: IT Owners can only view the Threat detection rules

8.4.3 IT Owner Settings Page

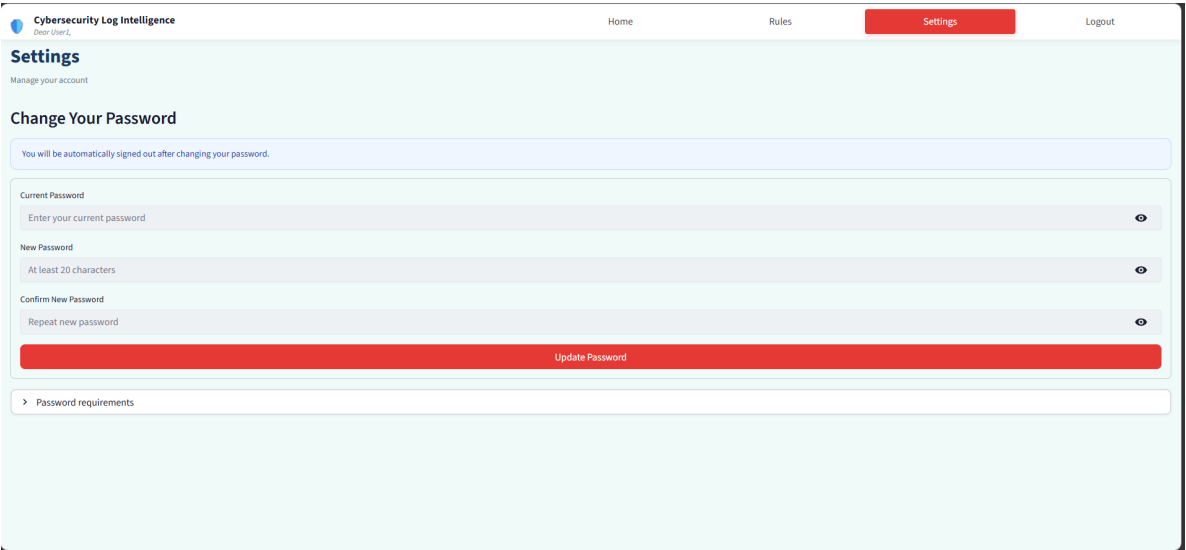
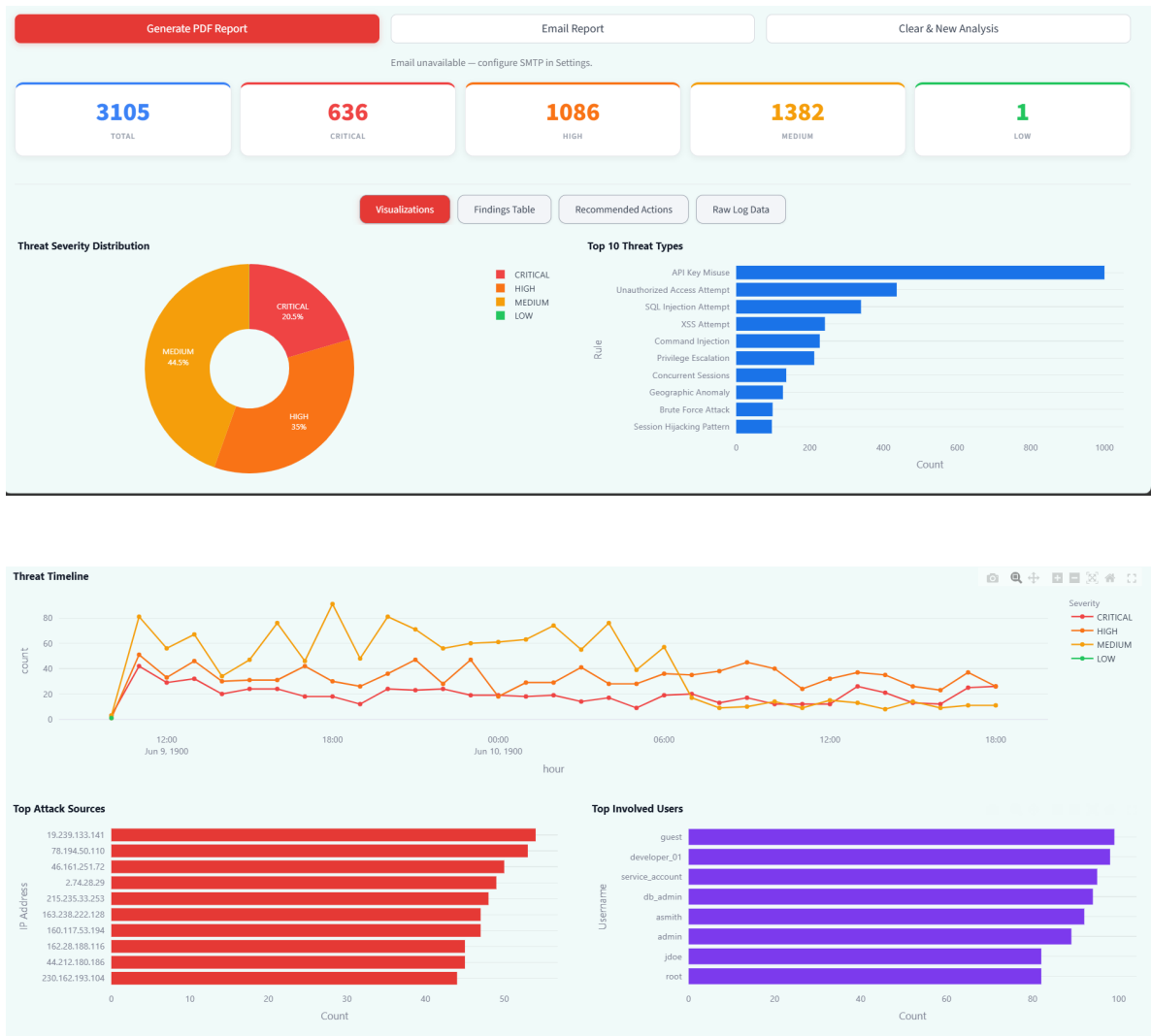


Figure 13: IT Owners can update its account password

8.5 Log Analysis Output

8.5.1 Visualizations



Rule	Severity	Count
API Key Misuse	MEDIUM	1000
Unauthorized Access Attempt	HIGH	436
SQL Injection Attempt	HIGH	339
XSS Attempt	MEDIUM	241
Command Injection	CRITICAL	227
Privilege Escalation	CRITICAL	212
Concurrent Sessions	HIGH	136
Geographic Anomaly	MEDIUM	127
Brute Force Attack	CRITICAL	99
Session Hijacking Pattern	CRITICAL	97
Account Lockout Event	HIGH	89
Path Traversal Attempt	HIGH	74
Successful Login After Failures	MEDIUM	9
Repeated Failed Logins	HIGH	8
Mass Data Access	MEDIUM	1
Configuration Change	MEDIUM	1
Error Rate Spike	MEDIUM	1
Resource Exhaustion	HIGH	1

8.5.2 Findings Table

VisualizationsFindings TableRecommended ActionsRaw Log Data

CRITICAL xHIGH xMEDIUM xLOW xINFO x

Showing3105 / 3105

Search by IP, username, rule, or description...

Showing first 500 of 3105 rows on screen — use the CSV download for the full set.

Severity	Rule	Source IP	Username	Timestamp	Line #	Description
CRITICAL	Command Injection	19.239.133.141	N/A	1900-06-09 10:32:14	1	Jun 09 10:32:14 srv-production-01 web_waf[2865]: [Source IP: 19.239.133.141] Security Alert: Pa
CRITICAL	Command Injection	111.205.27.237	N/A	1900-06-09 11:08:10	563	Jun 09 11:08:10 srv-production-01 web_waf[4568]: [Source IP: 111.205.27.237] Security Alert: Pa
CRITICAL	Command Injection	14.194.247.200	N/A	1900-06-09 11:12:43	749	Jun 09 11:12:43 srv-production-01 web_waf[3980]: [Source IP: 14.194.247.200] Security Alert: Pa
CRITICAL	Command Injection	167.253.155.36	N/A	1900-06-09 11:19:17	2007	Jun 09 11:19:17 srv-production-01 web_waf[191]: [Source IP: 167.253.155.36] Security Alert: Payl
CRITICAL	Command Injection	148.44.234.181	N/A	1900-06-09 11:30:06	7467	Jun 09 11:30:06 srv-production-01 web_waf[8368]: [Source IP: 148.44.234.181] Security Alert: Pa
CRITICAL	Command Injection	163.238.222.128	N/A	1900-06-09 11:31:26	8562	Jun 09 11:31:26 srv-production-01 web_waf[3876]: [Source IP: 163.238.222.128] Security Alert: P
CRITICAL	Command Injection	202.71.210.12	N/A	1900-06-09 11:35:14	9661	Jun 09 11:35:14 srv-production-01 web_waf[8818]: [Source IP: 202.71.210.12] Security Alert: Payl
CRITICAL	Command Injection	18.95.38.221	N/A	1900-06-09 11:35:44	9667	Jun 09 11:35:44 srv-production-01 web_waf[6274]: [Source IP: 18.95.38.221] Security Alert: Paylo
CRITICAL	Command Injection	45.121.47.90	N/A	1900-06-09 11:44:44	13058	Jun 09 11:44:44 srv-production-01 web_waf[1361]: [Source IP: 45.121.47.90] Security Alert: Paylo
CRITICAL	Command Injection	45.121.47.90	N/A	1900-06-09 11:47:39	14174	Jun 09 11:47:39 srv-production-01 web_waf[2324]: [Source IP: 45.121.47.90] Security Alert: Paylo
CRITICAL	Command Injection	7.249.55.39	N/A	1900-06-09 11:47:56	14179	Jun 09 11:47:56 srv-production-01 web_waf[3106]: [Source IP: 7.249.55.39] Security Alert: Paylo

Download findings (CSV)

8.5.3 Recommended Actions

VisualizationsFindings TableRecommended ActionsRaw Log Data

Recommended Actions

Immediate Response — CRITICAL:

→ Activate Incident Response Plan (IRP) immediately — do not wait

→ Isolate affected systems from the network to prevent lateral movement

→ Preserve forensic evidence — snapshot VM / copy logs before any changes

→ Notify the Security Operations Center (SOC) and CISO immediately

→ Escalate to management and legal if data breach is suspected

1. Command Injection

SEVERITY: CRITICAL

Issue: Command injection lets an attacker run arbitrary OS commands with the privileges of the application server.

→ Action: Isolate the host; never pass input to a shell — use allowlists and least-privilege service accounts.

2. Privilege Escalation

SEVERITY: CRITICAL

Issue: Privilege escalation attacks gain higher system access (root/admin) from a lower-privileged starting point.

→ Action: Isolate the host and revoke elevated rights; patch the exploited vector and audit all root actions.

3. Session Hijacking Pattern

SEVERITY: CRITICAL

Issue: Session fixation, CSRF, and session token mismatches suggest an active attempt to take over an authenticated session.

→ Action: Invalidate the user's sessions and regenerate IDs after auth; enforce HTTPS, SameSite and CSRF tokens.

8.5.4 Raw Log Data

VisualizationsFindings TableRecommended ActionsRaw Log Data

410,470 raw log entries parsed. Showing a sample of the first 1,000 entries.

line_num	timestamp	level	source_ip	message
1	1900-06-09 10:32:14	INFO	19.239.133.141	[Source IP: 19.239.133.141] Security Alert: Payload execution: cat /etc/shadow for user 'root'
2	1900-06-09 10:32:16	INFO	44.105.141.160	[Source IP: 44.105.141.160] Security Alert: Path access: .\..\windows\system32 for user 'guest'
3	1900-06-09 10:32:18	INFO	93.133.43.41	[Source IP: 93.133.43.41] User 'developer_01' successfully authenticated or accessed resource.
4	1900-06-09 10:32:22	INFO	103.106.200.102	[Source IP: 103.106.200.102] User 'asmith' successfully authenticated or accessed resource.
5	1900-06-09 10:32:28	INFO	44.105.141.160	[Source IP: 44.105.141.160] User 'developer_01' successfully authenticated or accessed resource.
6	1900-06-09 10:32:30	INFO	33.157.176.152	[Source IP: 33.157.176.152] User 'guest' successfully authenticated or accessed resource.
7	1900-06-09 10:32:38	INFO	54.40.6.177	[Source IP: 54.40.6.177] Security Alert: Input contained '<script>alert(1)</script>' for user 'root'
8	1900-06-09 10:32:40	INFO	125.88.244.21	[Source IP: 125.88.244.21] User 'db_admin' successfully authenticated or accessed resource.
9	1900-06-09 10:32:46	INFO	26.166.26.141	[Source IP: 26.166.26.141] Access Control Event: too many failures [Target User: guest]
10	1900-06-09 10:32:48	INFO	176.17.152.117	[Source IP: 176.17.152.117] Access Control Event: Login success after > 3 consecutive failures [Target User: roc

9 Conclusion

The Cybersecurity Log Intelligence System demonstrates that automated, enterprise-grade security monitoring can be achieved without compromising data privacy or operational resilience. By consolidating multi-file log analysis, framework-aligned threat detection, role-based governance, and automated reporting into a single platform, the solution directly addresses the inefficiencies and risks inherent in manual log review. The key outcomes of the project are summarized below.

- **Operational efficiency:** The system streamlines security operations by automating multi-file log analysis across 45 framework-aligned rules, reducing analyst workload and accelerating threat response.
- **Data governance and privacy:** On-demand reporting with no persistent storage of sensitive data ensures the solution meets stringent enterprise privacy and data-minimization requirements.
- **Enterprise-grade access control:** Role-based separation, Argon2id authentication, and enforced session policies uphold the principle of least privilege across all organizational stakeholders.
- **Scalability and business continuity:** Process-isolated workers with bounded concurrency and automatic fallback sustain performance under enterprise workloads while safeguarding service availability.
- **Compliance and audit readiness:** Standards-based rule mapping (MITRE ATT&CK, OWASP, NIST, ISO 27001, CERT-In) and comprehensive audit logging position the system for regulatory compliance and security assurance.
- **Actionable intelligence:** Interactive dashboards, severity-ranked findings, and concise recommended actions translate raw log data into clear, decision-ready insights for security teams.

In conclusion, the platform delivers a scalable, and compliance-ready foundation for enterprise log intelligence. Its privacy-first architecture and consistent enforcement of role boundaries make it well-suited for modern organizational deployment. Future enhancements may include integration with external SIEM platforms, real-time streaming log ingestion, and machine-learning-based anomaly detection to further strengthen its threat-identification capabilities.